Mobile Penetration Testing Documentation

Android (APK)

Android uses APK files and can be obtained on the Google Play Store. If it’s not available on the Play Store, a request for the APK file or a test flight invite should be sent to a Gmail.

An APK file on Play Store can be gotten from:

https://apkcombo.com/

https://apkpure.com/

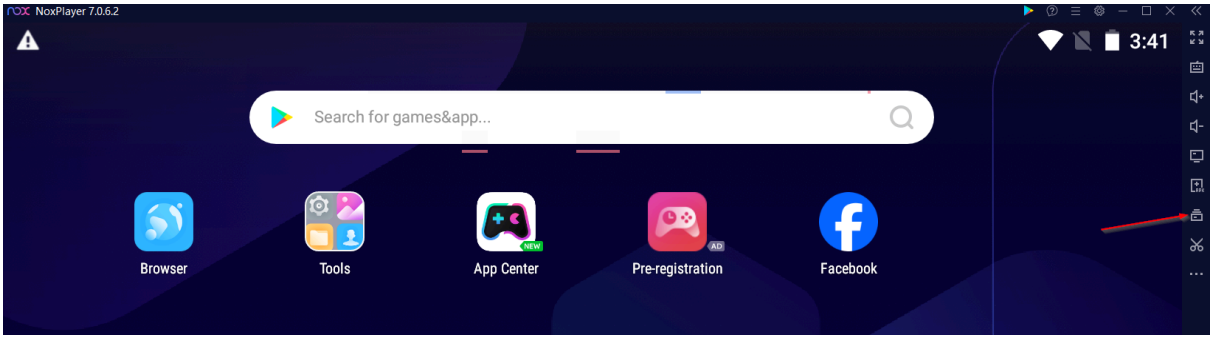
An Android emulator is used for the test, which includes:

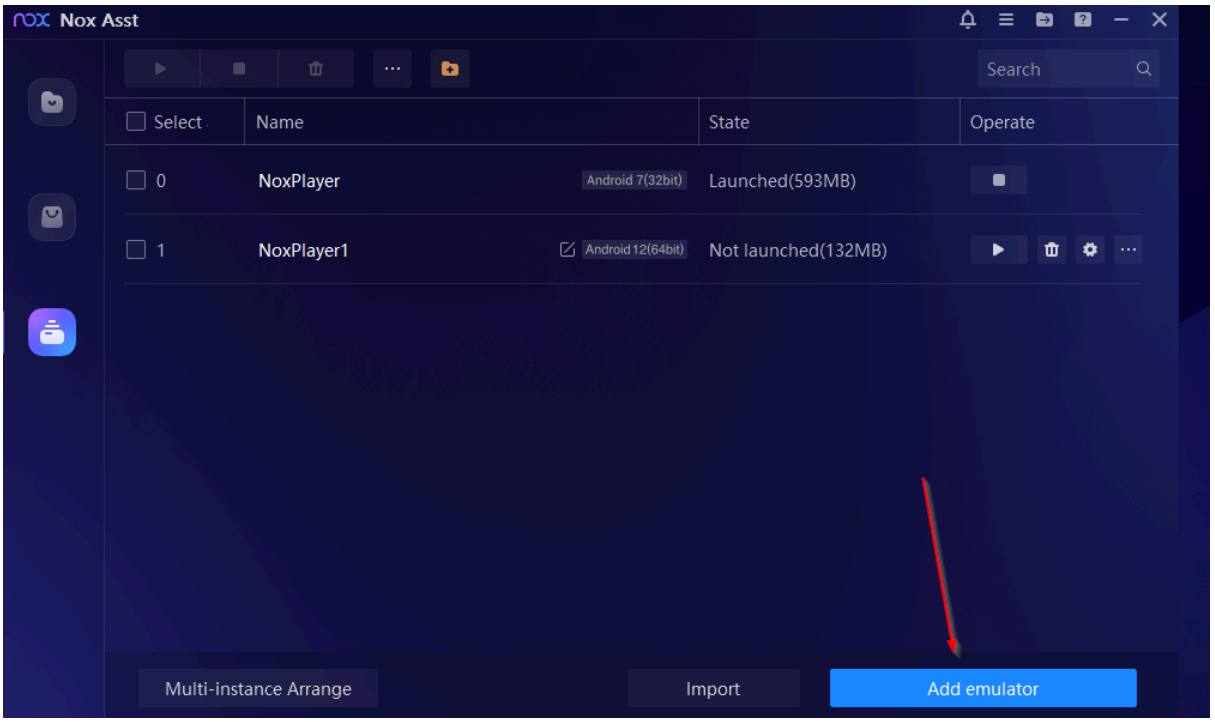
1. Nox player - https://www.bignox.com/
2. LDPlayer - https://www.ldplayer.net/
3. Android studio - https://developer.android.com/studio
4. Genymotion - https://www.genymotion.com/product-desktop/download/

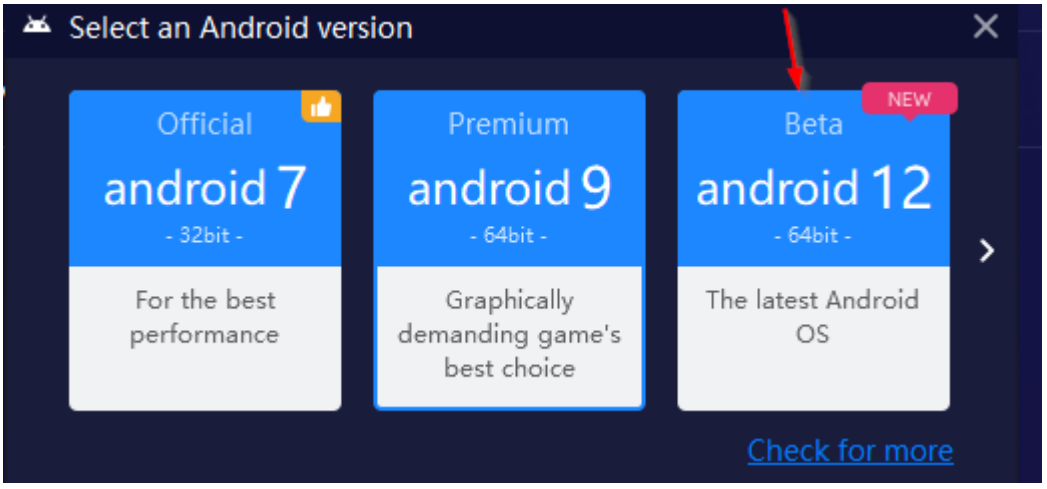
Steps to use Nox Player

1. Install the application on your system.

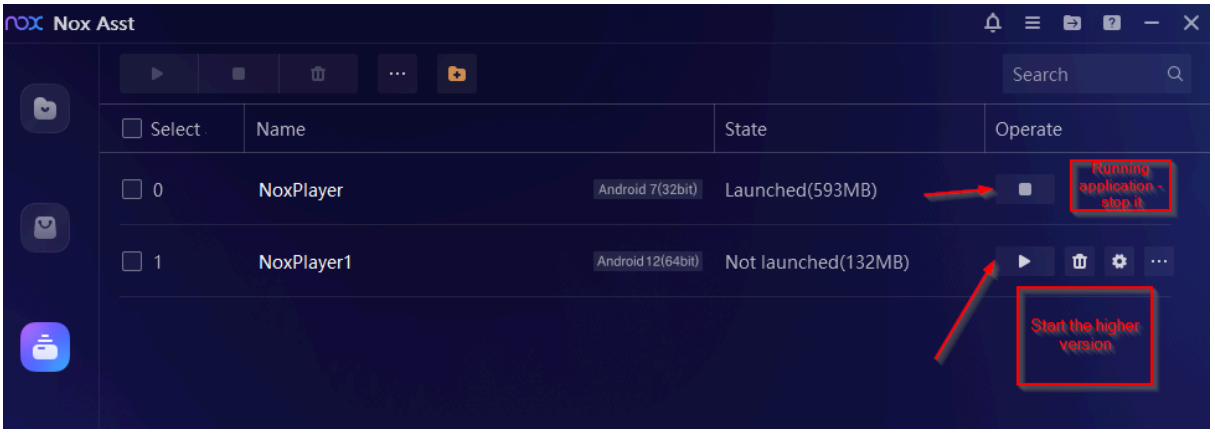
Once the application is up, click on the icon in the image below to add another emulator - higher android version.



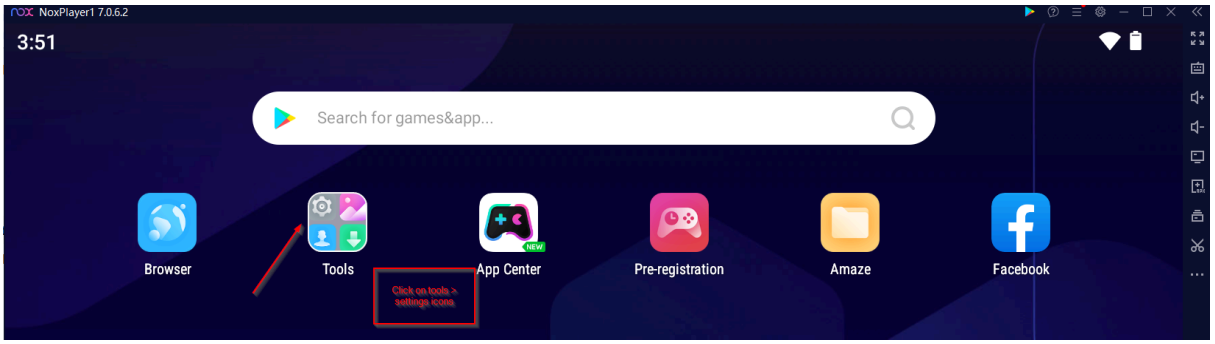




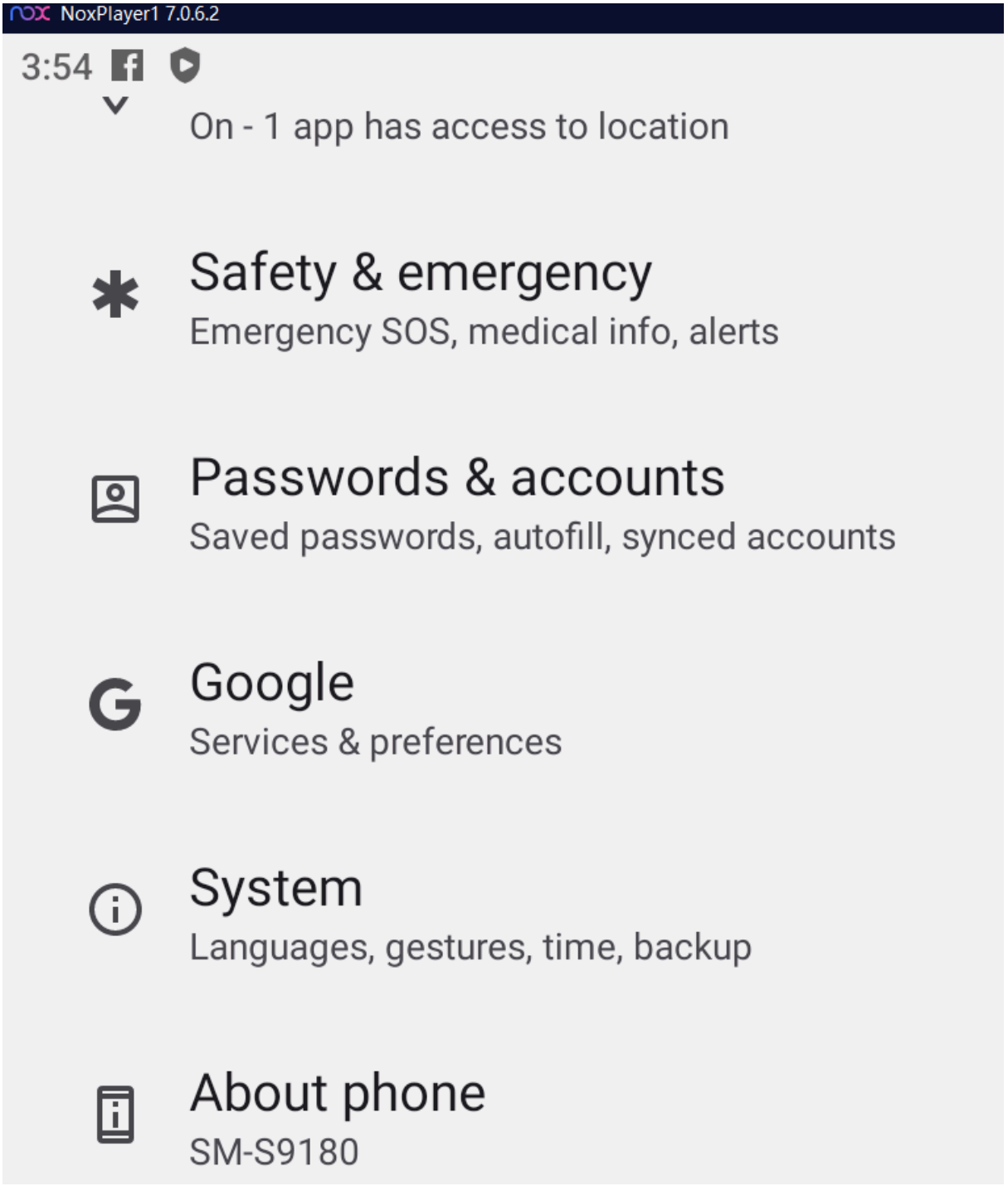
Once it has been added, stop other emulators and start the higher version.



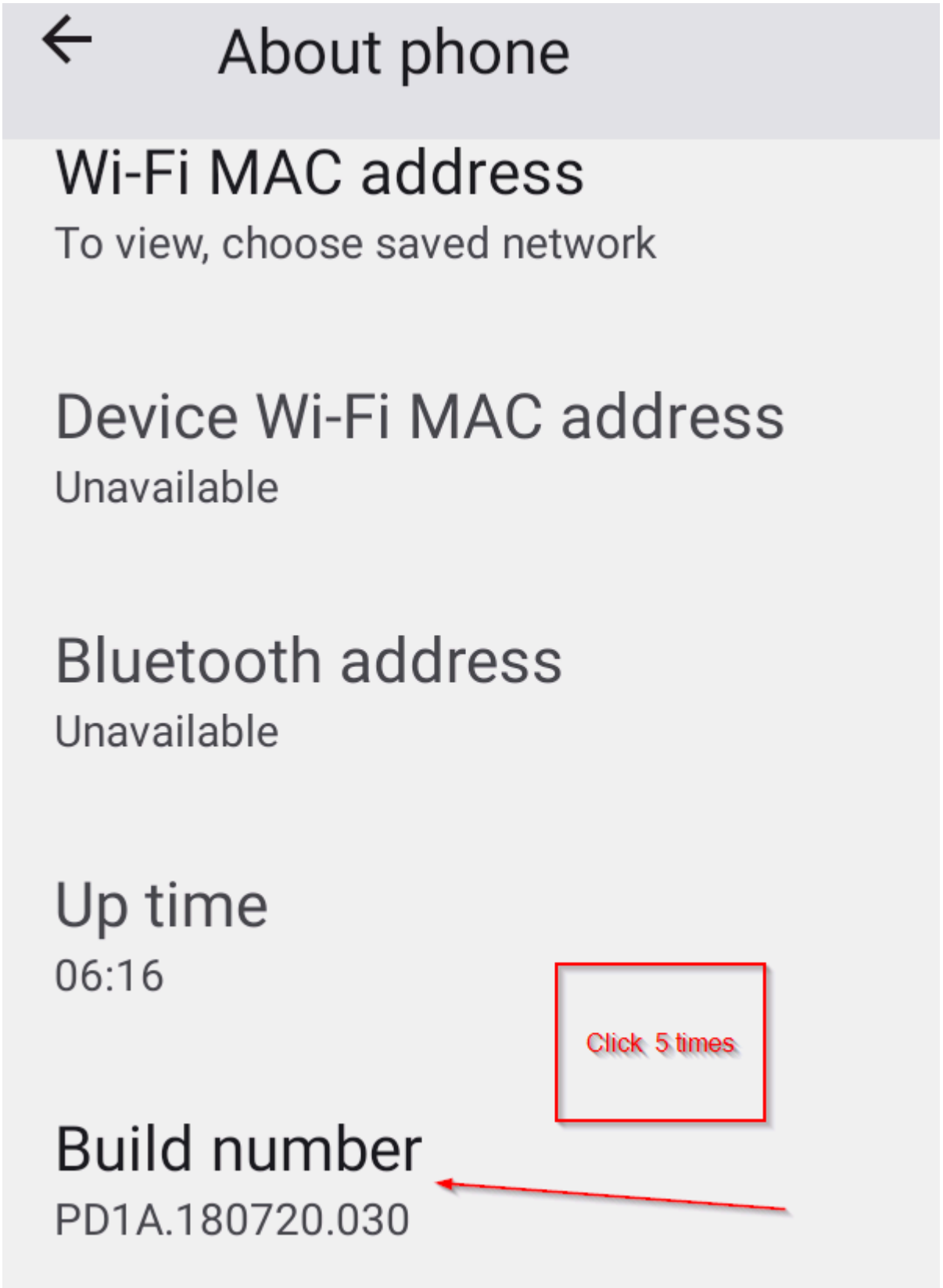
2. Set the device to developer mode by following the images below



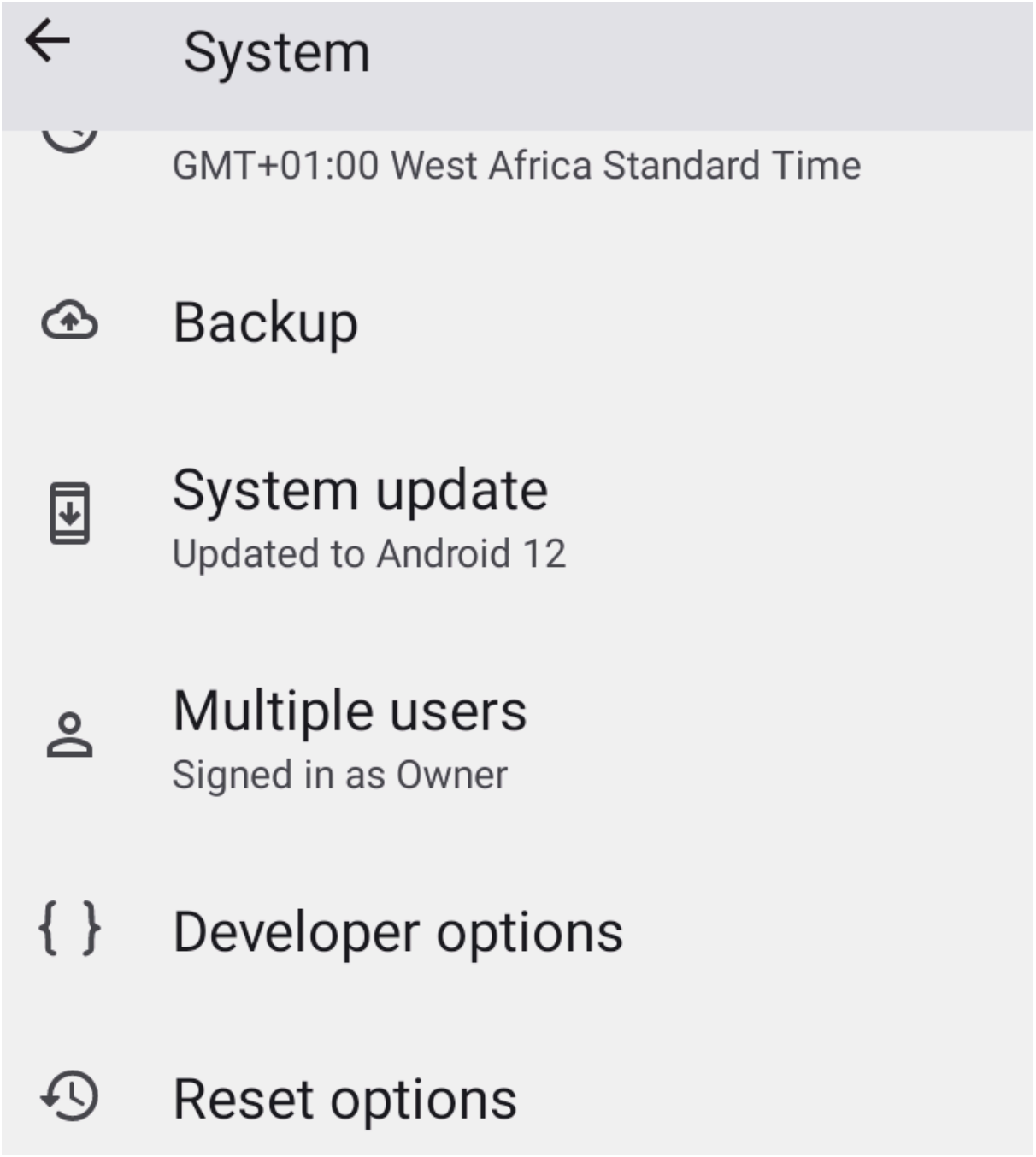
Click on about phone.



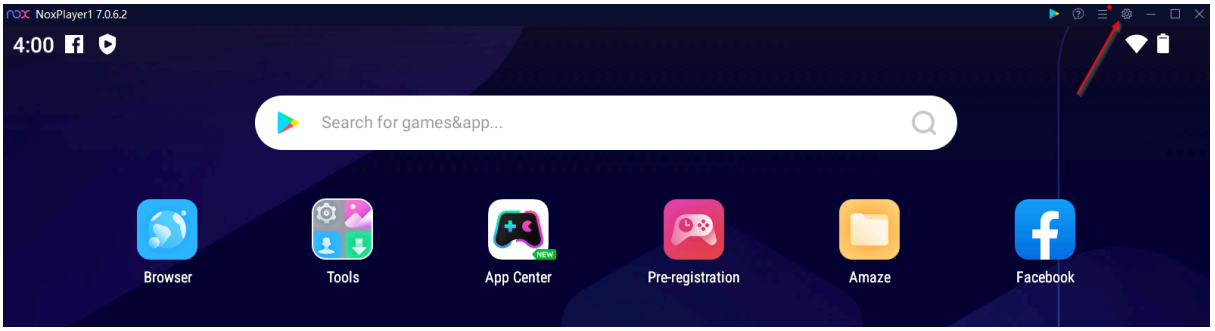
Scroll down and tap on build number 5 times to get the developer option.



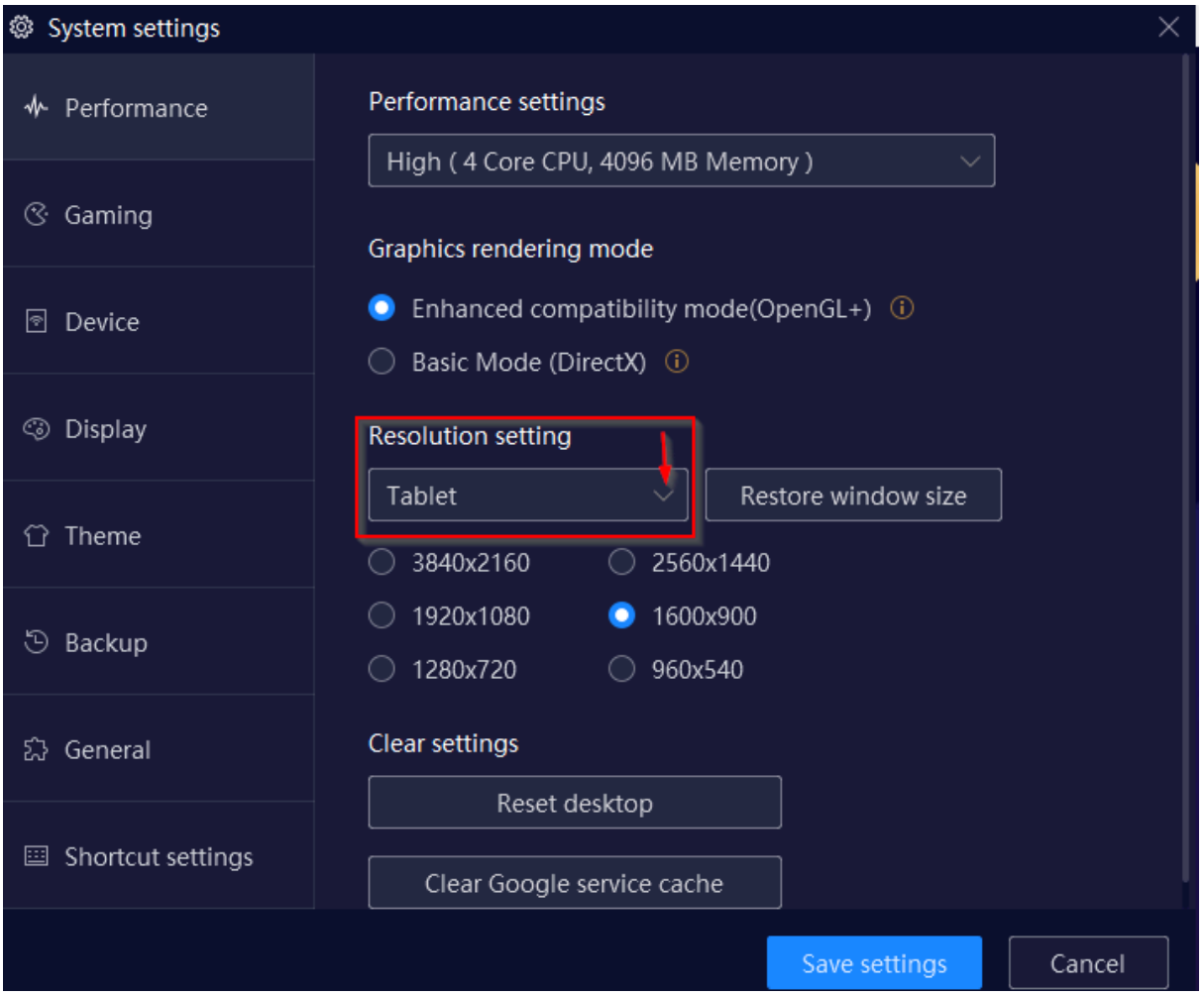
Go one-step backward and click on system. Then you see the developer options



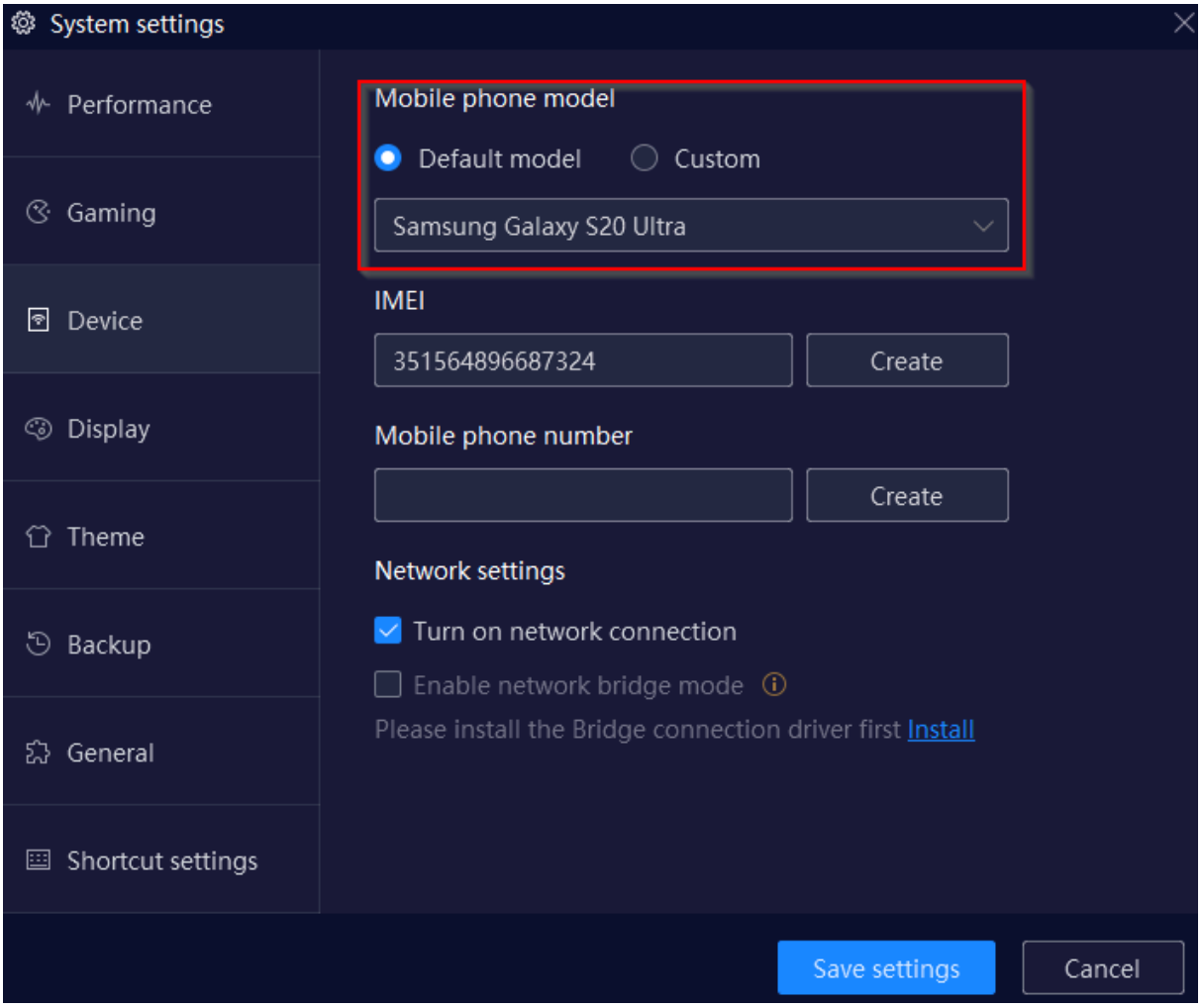
3. Click on the settings icon as seen in the image below for further configuration



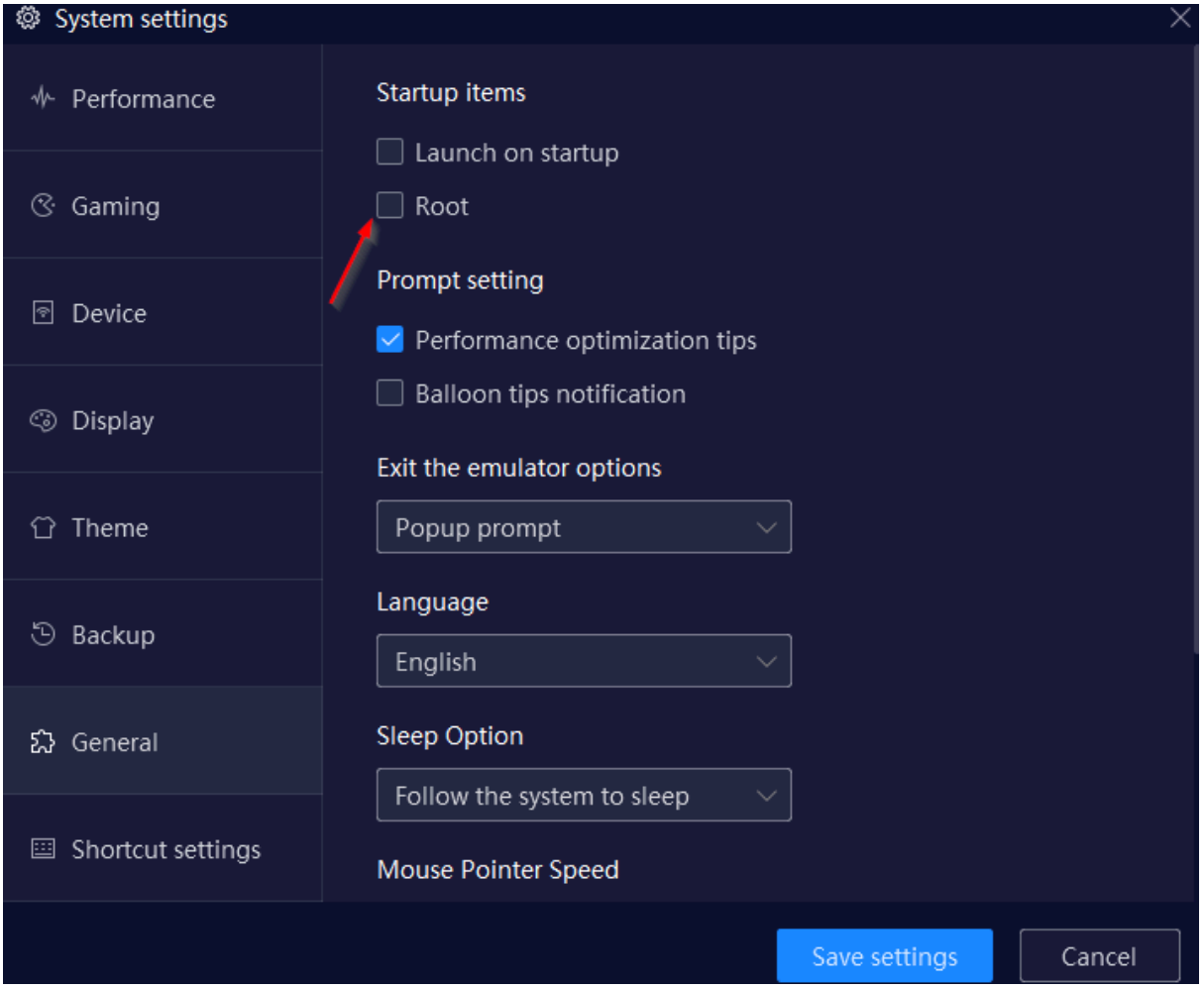
The first option is **performance**. Here, use the drop-down arrow beside **resolution settings** to change it to mobile phone.



Under device, you will see the mobile phone model, such as Samsung, Google pixel. Changing it is optional.



Under **General**, check the root box.



Save the settings.

4. Connect to the device using Android Debugger (adb).

Open your command prompt > go the the nox directory (`cd C:\Program Files (x86)\Nox\bin`) > `adb devices` > `adb connect <device ip address:port no>`

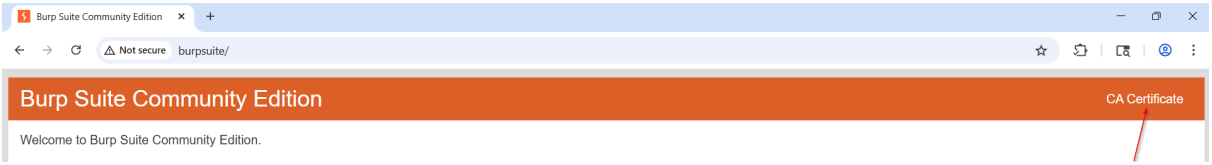
```
C:\Program Files (x86)\Nox\bin>adb devices
List of devices attached
127.0.0.1:62025 device


C:\Program Files (x86)\Nox\bin>adb connect 127.0.0.1:62025
already connected to 127.0.0.1:62025

C:\Program Files (x86)\Nox\bin>
```

5. Download burpsuite certificate.

start burp > proxy > open browser > visit http://burpsuite > click download CA



6. Copy the certificate to your Linux to convert to digits.

- `openssl x509 -inform DER -in cacert.der -out cacert.pem`
- `openssl x509 -inform PEM -subject_hash_old -in cacert.pem | head -1`
- `mv cacert.pem <output.0>` - For example: if the second command displays 9a5gfyt, then use `mv cacert.pem 9a5gfyt.0`

Copy the new file (`9a5gfyt.0`) to the nox directory.

7. You can do step 4 again or continue from step 7. Run the following:

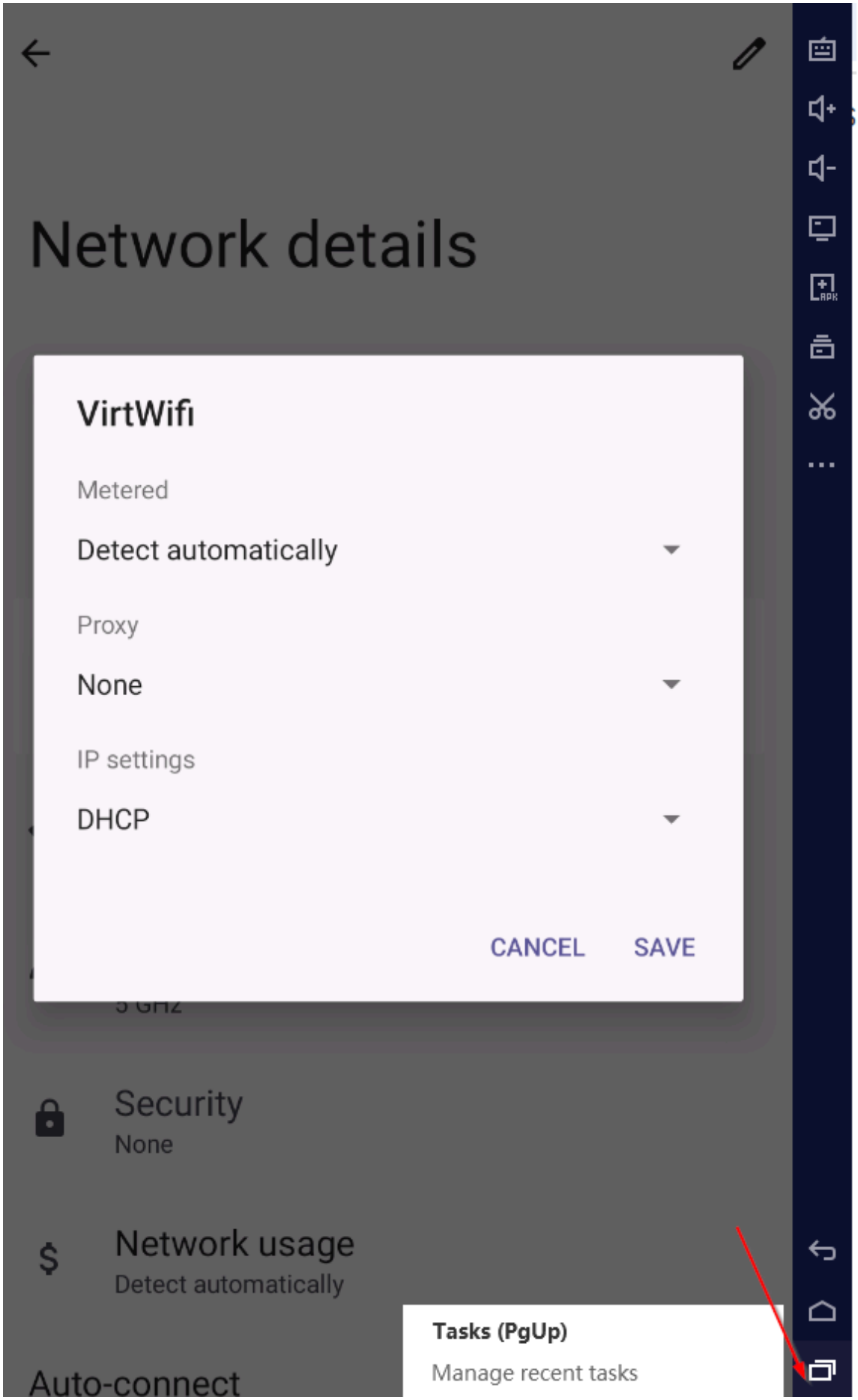
- `adb remount`
- `adb push 9a5gfyt.0 /system/etc/security/cacerts`
- `adb shell`
- `chmod 777 /system/etc/security/cacerts/9a5gfyt.0`

Restart the emulator

8. Repeat step 4. If you have the APK file in Nox directory, install it with the following command on the emulator: `adb install <filename.apk>`
9. Set up a manual proxy on the emulator.

To do this, right-click at the top of the device and drag down twice >

click on emergency call only > click on internet > settings icon > edit icon > drop-down beside advanced options > manual > drop-down beside none > click on the image in the image below > click manual > open your command prompt to check your IP address > set the proxy hostname to your system IP address (For example: if the IP is 192.168.0.5) and the proxy port to 8080 > save


Network details
VirtWifi
Metered
Detect automatically
Proxy
None
IP settings
DHCP
CANCEL
SAVE
Security
None
Network usage
Detect automatically
Auto-connect
Tasks (PgUp)
Manage recent tasks

Bypass SSL Pinning with Frida

First installation process

Download and install Python 3
https://www.python.org/downloads/release/python-3133/

1. Download frida server https://github.com/frida/frida/releases

Note: download **frida-server-x.x.x-android-x86_64.xz**

2. Extract the file and move it to the nox directory
3. Do step 4 above and the following

`adb push` **`frida-server-x.x.x-android-x86_64`** `/data/local/tmp`

`adb shell`

`chmod 777 /data/local/tmp/frida-server-x.x.x-androind-x86_64`

4. Open another command prompt and go to the nox directory.

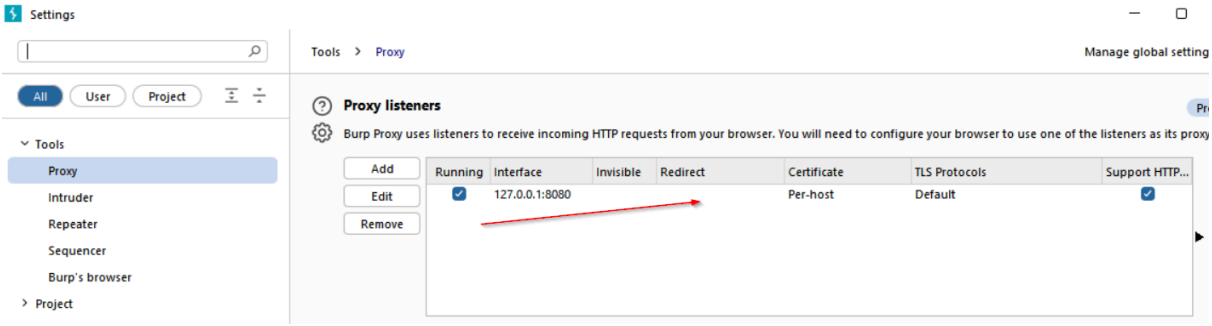
Install Frida tools - `pip3 install frida-tools`

Install objection - `pip3 install objection`

Subsequently, do the following:

On your burpsuite, do the following to allow traffic through it.

click proxy settings > select the information in the image below > click edit > check all interface > ok



https://medium.com/@vaishalinagori112/9-different-ways-to-bypass-ssl-pinning-in-android-2d8c7f81b837

1. Open your command prompt and go to the nox directory
2. Do step 4 above, and the following:

`adb shell`

`cd /data/local/tmp`

`./frida-server-x.x.x-androind-x86_64`

3. While the server is running, open another command prompt and go to the nox directory
4. Get all applications on the emulator - `frida-ps -Uai`
5. Run objection - `objection -g <the appname> explore`. Example: `objection -g com.example.com explore`
6. Run - `android sslpinning disable`